

GRCeek High-Level Architecture

This document provides a high-level architecture overview for the GRCeek platform, detailing key business requirements and the proposed technical architecture.

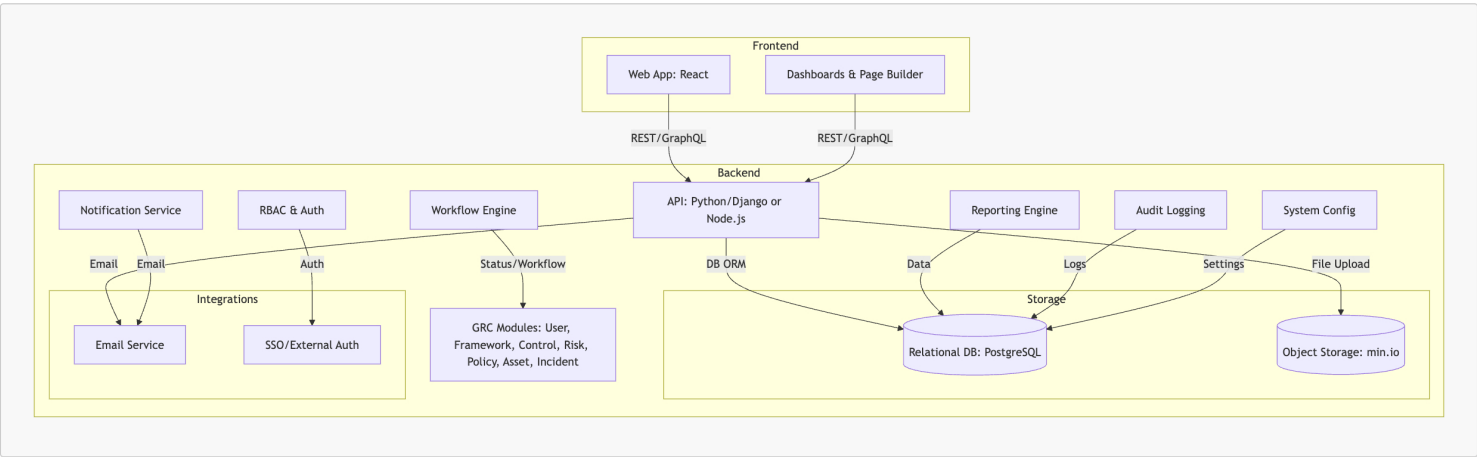
1. Business Requirements

The GRCeek platform is designed to meet a comprehensive set of business requirements, ensuring a robust, secure, and user-friendly experience for Governance, Risk, and Compliance (GRC) management.

- User Management with RBAC and Invitation Flows:** The system must support the creation, modification, and deletion of user accounts. It will incorporate Role-Based Access Control (RBAC) to define user permissions and facilitate secure invitation flows for new users to join the platform.
- Framework, Control, Risk, Policy, and Asset Management (CRUD, Linking, Status Workflows):** Core GRC entities will be managed within the system. This includes full Create, Read, Update, and Delete (CRUD) functionality for frameworks (e.g., ISO 27001, NIST), individual controls, identified risks, organizational policies, and critical assets. The system will enable linking these entities to demonstrate relationships and dependencies (e.g., a control mitigating a specific risk, a policy governing an asset). Furthermore, it will support customizable status workflows to track the lifecycle and approval processes of each entity.
- Workflow Management (Customizable, Drag-and-Drop):** A flexible workflow engine is required to define and automate business processes related to GRC activities. Users should be able to design and modify workflows using an intuitive drag-and-drop interface, adapting them to specific organizational needs.
- Custom Reports and Real-time Dashboards:** The platform will provide powerful reporting capabilities, allowing users to generate custom reports based on various GRC data points. Real-time dashboards will offer immediate insights into the organization's GRC posture, highlighting key metrics, compliance status, and risk exposure.
- System Configurations (Categories, Settings):** Administrators will have the ability to configure various system-wide settings, including the definition of categories for different GRC entities (e.g., risk types, control families) and other operational parameters to tailor the platform to their environment.
- Roles & Permissions (Granular, Per Module):** Beyond basic RBAC, the system will offer granular control over permissions, allowing administrators to define specific actions users can perform within each module (e.g., view only policies, edit risks, approve controls).
- Incident Reporting (Lifecycle, Evidence Upload):** A dedicated module for incident management will support the full lifecycle of an incident, from initial reporting and categorization to investigation, resolution, and post-mortem analysis. It will facilitate the upload and attachment of evidence related to incidents.
- Page Builder (Custom UI/Pages):** To enhance flexibility, a page builder feature will enable users to create custom user interfaces or pages within the platform, allowing for tailored views and data presentation without requiring code changes.
- Notifications (Template-based, Role-based, Email/In-app):** The system will provide a robust notification mechanism to alert users about important events, workflow changes, or upcoming tasks. Notifications will be template-based for consistency and can be configured to be role-based, delivered via email, or as in-app messages.
- Security (Encryption, RBAC, Audit Logging):** Security is paramount. The platform will implement data encryption at rest and in transit, enforce RBAC for access control, and maintain comprehensive audit logs of all user activities and system changes to ensure accountability and compliance.
- Performance (<4s Response, 1,000 Users):** The system must be highly performant, with a target response time of less than 4 seconds for typical operations, even under a load of up to 1,000 concurrent users.
- Usability (Responsive UI, Accessibility):** The user interface will be designed for optimal usability, featuring a responsive layout that adapts seamlessly to various devices (desktop, tablet, mobile) and adhering to accessibility standards to ensure inclusivity.
- Availability (95% Uptime, DR):** The platform is expected to maintain a high level of availability, targeting 95% uptime. A disaster recovery (DR) strategy will be in place to ensure business continuity in the event of major disruptions.
- Maintainability (Clean Code, Docs):** The codebase will be developed with maintainability in mind, following best practices for clean code, modular design, and comprehensive documentation to facilitate future enhancements and troubleshooting.

2. High-Level Technical Architecture

The GRCeek platform adopts a modular, service-oriented architecture, separating concerns between the frontend, backend, storage, and external integrations to ensure scalability, flexibility, and maintainability.



2.1. Frontend

- Web App (React):** The primary user interface, built with React for modularity, reusability, and efficient rendering. Provides a responsive, interactive experience for all user roles.
- Dashboards & Page Builder:** Integrated within the React app. Dashboards use data visualization for real-time insights. The Page Builder offers a drag-and-drop interface for custom UI/pages, allowing users to tailor their experience.

2.2. Backend

- API (Python/Django or Node.js):** Exposes a robust REST/GraphQL API for all frontend interactions. Central hub for business logic, data validation, and orchestration.
- RBAC & Auth:** Manages user authentication (login, SSO) and authorization (RBAC), enforcing permissions and session management.
- GRC Modules:** Core business logic for User, Framework, Control, Risk, Policy, Asset, and Incident management. Handles CRUD, linking, and workflows.

- **Workflow Engine:** Manages creation, execution, and monitoring of custom workflows. Updates entity statuses as they progress through defined processes.
- **Notification Service:** Generates and dispatches notifications (email/in-app), integrating with the Email Service and supporting template/role-based configs.
- **Reporting Engine:** Aggregates and transforms data for custom reports and dashboards, providing actionable GRC insights.
- **Audit Logging:** Records all significant user actions and system events for compliance, security, and forensic analysis.
- **System Config:** Manages system-wide settings, categories, and operational parameters for platform customization.

2.3. Storage

- **Relational DB (PostgreSQL):** Primary database for structured data. Chosen for robustness, ACID compliance, and support for complex relational GRC data. Accessed via ORM.
- **Object Storage (min.io):** S3-compatible storage for unstructured data (e.g., evidence files). Scalable and cost-effective for large file volumes.

2.4. Integrations

- **Email Service:** Used by the Notification Service to send alerts, password resets, and communications.
- **SSO/External Auth:** Integrates with enterprise SSO providers or external authentication systems for secure, seamless user login.

Data Model

- **Entity-Relationship Structure:** The model is organized around clear relationships between core entities such as users, groups, roles, assets, requirements, controls (reference and applied), assessments (compliance, risk, entity), vulnerabilities, incidents, findings, and security exceptions.
- **Folder-Based RBAC:** Access control is managed through a folder-based Role-Based Access Control (RBAC) system, supporting both global and domain-specific permissions, with roles and assignments mapped to Django conventions (add, view, change, delete).
- **Extensibility:** The model supports integration of external frameworks, libraries, and mappings, allowing organizations to import standards (e.g., ISO, NIST), risk matrices, and control catalogs, and to define custom requirements, controls, and mappings.
- **Internationalization:** Referential objects (frameworks, requirements, controls, threats) support multi-language translations, enabling global deployments and localized user experiences.
- **Comprehensive Assessment Support:** The model enables detailed compliance, risk, and third-party (TPRM) assessments, including requirement mapping, scoring, evidence management, and review workflows.
- **Advanced GRC Concepts:** Includes support for security objectives, disaster recovery metrics (RTO, RPO, MTD), risk matrices, qualifications, and mapping to methodologies like EBIOS-RM and Open FAIR.
- **Third-Party Risk Management:** Entities, solutions, contracts, and entity assessments are modeled to support TPRM workflows, including provider evaluations and compliance reviews.
- **Auditability and Traceability:** All objects include creation and modification timestamps, and the model supports audit logging and evidence attachment for compliance and incident management.
- **Labeling and Analytics:** User-defined labels can be attached to most objects, enabling flexible filtering and analytics across the platform.

Core Entities and Relationships

- **Users, Groups, Roles:** Manage access and permissions, supporting SSO and local authentication.
- **Assets:** Represent primary and supporting assets, with hierarchical relationships and disaster recovery objectives.
- **Requirements & Controls:** Frameworks define requirements (nodes), which are assessed and mapped to applied controls. Reference controls serve as templates for applied controls.
- **Assessments:** Compliance, risk, and entity assessments are supported, each with their own review, scoring, and evidence mechanisms.
- **Vulnerabilities & Incidents:** Track weaknesses, findings, and security events, with links to assets, controls, and risk scenarios.
- **Security Exceptions:** Document and manage deviations from standard controls or requirements, with approval workflows.
- **Libraries & Mappings:** Support for importing and managing external standards, mappings, and risk matrices, with versioning and dependency management.

Access Control and Security

- **RBAC Model:** Fine-grained permissions at the object and folder/domain level, with built-in and custom roles.
- **Published Objects:** Global referential objects can be published for read-only access across domains.
- **Audit Logging:** All changes and actions are tracked for compliance and forensic purposes.

Internationalization and Customization

- **Translations:** All referential objects can be translated, supporting multi-lingual deployments.
- **Custom Scoring and Workflows:** Score scales, requirement mappings, and workflow states are configurable to match organizational needs.

GRC Frameworks

GRCeek provides comprehensive support for GRC frameworks and standards, enabling organizations to manage compliance with regulations and best practices such as ISO 27001, NIST, CIS, CMMC, and others. Key features include:

- **Frameworks as Core Objects:** Each framework represents a standard (e.g., ISO 27001:2013, NIST) and is composed of a tree of requirement nodes (requirements), which can be assessable or informational.
- **Implementation Groups:** Support for grouping requirements (e.g., CMMC, CIS) to tailor assessments and reporting.
- **Customizable Scoring:** Each framework has a score scale (default 0-100, customizable per framework or assessment). Custom score definitions (e.g., TISAX levels) are supported.
- **Requirement Mapping:** Requirement nodes can be linked to reference controls and threats, providing traceability and mapping between frameworks, controls, and risks.
- **Reference Controls:** Templates for applied controls, categorized (Policy, Process, Technical, Physical) and mapped to NIST CSF functions (Govern, Identify, Protect, Detect, Respond, Recover).
- **Requirement Mapping Sets:** Support for mapping requirements between source and target frameworks (e.g., NIST to ISO), enabling crosswalks and automated compliance inference.
- **Library Import:** Frameworks, controls, threats, and mappings can be imported as libraries, with versioning and dependency management.
- **Extensibility:** The data model allows importing new frameworks and defining custom requirements, controls, and mappings.

Standards explicitly mentioned or supported:

- ISO 27001:2013
- NIST (including CSF functions)
- CIS (implementation groups)
- CMMC (implementation groups)
- TISAX (custom score definitions)
- FIPS-199 (risk/impact scale)